Computer Security & Forensics

CSE 461 | Session 2020-21 | Final exam

Model study answers. Every listed option is addressed. Question titles are paraphrased; exact wording and original diagrams are in the source pages appended to this pack.

Quick revision

Case-sensitive alphanumeric strings of length L: 62^L (repetition allowed).

Euler phi(n): count integers 1..n coprime to n. phi(14)=6.

ElGamal: y=g^x mod p; c1=g^k mod p; c2=M y^k mod p.

ElGamal decryption: M=c2 (c1^x)^(-1) mod p.

RSA textbook identity: (m^d)^e = m mod n. Real signatures use secure encoding such as RSA-PSS.

Toy rolling hash in this paper: d_i=(26 d_(i-1)+letter_value) mod 107.

1(a) | Why the CIA triad matters

Confidentiality prevents unauthorized disclosure; integrity prevents or detects unauthorized modification; availability keeps authorized services accessible. A vulnerable environment can threaten all three: stolen grades violate confidentiality, altered grades violate integrity, and a disabled registration portal violates availability. Security controls must address the three goals together.

Revision answer: Protect secrecy, correctness and access to services.

1(b) | Number of 6-character alphanumeric passwords

Assume 26 uppercase letters, 26 lowercase letters and 10 digits, with repetition allowed. Each of 6 positions has 62 choices, so total=62^6=56,800,235,584. If the examiner means case-insensitive letters, the answer is 36^6 instead. State the character-set assumption.

Revision answer: 62^6 = 56,800,235,584 under the case-sensitive assumption.

1(c) | Ciphertext shorter than the unicity distance

Unicity distance is an approximate ciphertext length beyond which language redundancy may leave roughly one plausible key for an idealized cipher model. Below it, several keys and meaningful plaintexts may remain consistent with the ciphertext. Even exhaustive search may not uniquely identify the intended plaintext without extra information. This is not a universal security guarantee for every cipher.

Revision answer: The attacker may face multiple plausible keys and plaintexts.

1(d) | Most time-efficient access-control mechanism

The wording does not specify the query or data structure, so there is no universal winner. An access-control matrix directly represents subject-object permissions and is often the intended conceptual answer for arbitrary access queries. A densely indexed matrix can answer a specific permission lookup quickly but uses substantial space. ACLs organize permissions by object; capability lists organize them by subject. Explain that efficiency depends on the query and representation rather than claiming one always wins.

Revision answer: Likely intended: access-control matrix; actual efficiency depends on query and storage.

1(e) | Two tools of integrity

A message authentication code detects unauthorized changes when a secret key is shared. A digital signature also detects changes and can authenticate the signer using a public key. A cryptographic hash can detect changes only when its expected digest is obtained through a trusted channel; an attacker can replace an unprotected file and its hash together.

Revision answer: MACs and digital signatures protect integrity.

1(f) | Find Z*14 and phi(14)

Z*14 consists of residues from 0 to 13 having gcd(a,14)=1. Remove multiples of 2 and 7. The remaining residues are {1,3,5,9,11,13}. There are 6, so phi(14)=6. Also phi(14)=14(1-1/2)(1-1/7)=6.

Revision answer: Z*14={1,3,5,9,11,13}; phi(14)=6.

1(g) | Why security by obscurity is insufficient

If security depends only on hiding the design, discovering or leaking that design defeats the defense. Publicly reviewed mechanisms can remain secure when the algorithm is known, provided keys remain secret. Obscurity may add friction but should not replace sound cryptography, access control and review.

Revision answer: Keep keys secret; do not depend solely on a secret design.

1(h) | Why OFB cannot generate all blocks in parallel

OFB generates O_i=E_K(O_(i-1)), starting from an IV. Each keystream block therefore depends on its predecessor, so keystream generation is sequential. Once the keystream has been precomputed, XORing it with data blocks can be parallelized. CTR instead generates independent counter blocks.

Revision answer: OFB keystream generation is chained; only the later XOR stage is parallelizable.

2(a) | Why asymmetric encryption is needed

Symmetric encryption is efficient but requires the parties to establish a shared secret securely. Public-key techniques help establish keys without first sharing that secret and support digital signatures. A hybrid system authenticates parties and establishes a session key using public-key mechanisms, then encrypts bulk data symmetrically. Public keys still need authentication to prevent substitution.

Revision answer: Public-key methods help key establishment and signatures; symmetric methods handle bulk data.

2(b) | Security principles violated by the SUST scenario

A privately designed encrypted channel without demonstrated public scrutiny raises an open-design concern; merely being proprietary does not prove it is broken. Allowing every visitor to access every student result indicates missing authorization and least-privilege enforcement if those records are intended to be private. Encryption protects the channel but cannot correct overly broad application permissions. Use reviewed transport protection, authenticate users, authorize each record access and audit accesses. The scenario does not establish an availability failure.

Revision answer: Likely issues: open design, least privilege and confidentiality through missing authorization.

2(c) | Compare Password A and Password B

A has 10 case-sensitive letters: 52^10=144,555,105,949,057,024 possibilities if sampled uniformly. B has 4 letters, 3 digits and 2 symbols, so it has 9 characters, not 10. Let s be the number of allowed symbols. If category positions are fixed, B has 52^4 x 10^3 x s^2 possibilities. If any arrangement is allowed, multiply by 9!/(4!3!2!)=1260. For exactly three allowed symbols, these counts are 65,804,544,000 and 82,913,725,440,000 respectively, both below A. The printed examples do not fix the symbol alphabet or position rule, so B has no single unqualified numerical count. Under these conventional assumptions and uniform selection A is stronger mathematically; practical strength depends on randomness, reuse, leaks and guessing patterns. Composition alone does not determine security.

Revision answer: A wins under the stated three-symbol examples; B requires explicit alphabet and placement assumptions.

2(d) | AES mode for a video with missing blocks

CTR is a suitable confidentiality-mode answer: each block uses E_K(nonce,counter), so an independently addressed surviving block can be decrypted even when another is lost. CBC depends on neighboring ciphertext; OFB needs synchronized keystream position. ECB has independence but leaks patterns and should not be chosen for that reason. In a real streaming design, use authenticated encryption per independently numbered packet or chunk, with correct nonce uniqueness and replay handling. If the transport removes bytes without preserving offsets, no mode automatically restores synchronization.

Revision answer: CTR fits independent block access; practical systems should authenticate separate chunks.

2(e) | Public-key versus private-key cryptography

Symmetric/private-key encryption uses the same secret key for encryption and decryption, is efficient for large data, and requires secure secret distribution. Asymmetric/public-key encryption uses a public/private key pair; data encrypted to a public key is decrypted with its private key. Public-key signatures use a signing key and a public verification key. They ease key distribution but require authentic public keys and are generally more expensive. Neither approach is inherently secure without good algorithms, key management and implementation.

Revision answer: Symmetric: shared secret and speed. Asymmetric: key pairs, key establishment and signatures.

2(f) | Decrypt CB7F1 using the S-box

Read an input nibble as row=first two bits and column=last two bits. The printed rows, in hexadecimal, are 00: [3,4,F,1]; 01: [A,6,5,B]; 10: [E,D,4,2]; 11: [7,0,9,C]. Decryption searches for each ciphertext output and returns its input position. C occurs at input 1111=F; B at 0111=7; 7 at 1100=C; F at 0010=2; 1 at 0011=3. Therefore CB7F1 decrypts to F7C23. The scanned table repeats output 4 (at inputs 1 and A) and omits output 8, so it is not a bijection as printed. Those issues do not create ambiguity for this particular ciphertext, which contains neither 4 nor 8.

Revision answer: Plaintext F7C23; the printed S-box has a duplicate output elsewhere.

3(a)(i) | Design and verify an RSA e-certificate system

Setup: SUST creates an RSA signing key pair in protected storage and distributes an authenticated verification key through a trusted certificate chain. Issuance: form a canonical credential containing student identity, degree, issuer, unique serial and issue date; hash and sign it using a standard RSA signature scheme such as RSA-PSS. Holder: the student stores the document with its signature. Verification: the authority obtains the trusted issuer key, checks validity and revocation status, recomputes the credential hash and verifies the signature. A changed credential fails verification. In the textbook abstraction, s=m^d mod n and s^e mod n=m follows from the RSA exponent relation; real RSA-PSS verifies an encoded hash, not raw document exponentiation.

Revision answer: Issuer signs; student holds; verifier checks the signature using SUST's authenticated public key.

3(a)(ii) | Remaining threats to e-certificates

Consider theft of the issuer signing key, fraudulent issuance, forged identity at enrollment, malicious administrators, key substitution, implementation errors, altered verification software, replay of revoked credentials and denial of service. Use hardware-backed key protection, limited signing permissions, audited issuance, key rotation, revocation checking, secure verification and recovery procedures. A valid signature proves issuer authentication and integrity; it does not independently prove the issuer's claim was truthful.

Revision answer: Protect issuance, signing keys, identity checks and revocation, not only the signature algorithm.

3(b)(i) | Problems with AES-ECB for student data

ECB encrypts identical plaintext blocks to identical ciphertext blocks under the same key. It reveals repeated structures in images and documents and allows block substitution/reordering without built-in authentication. AES-256 key size does not remove these mode-level weaknesses. Use suitable authenticated encryption with carefully managed nonces.

Revision answer: ECB leaks patterns and provides no message authentication.

3(b)(ii) | Would RSA be better for bulk student data?

RSA is unsuitable for directly encrypting large images and documents: inputs have strict size limits and operations are expensive. A hybrid design uses a fresh symmetric key for authenticated data encryption and protects that key with an appropriate public-key mechanism. RSA-OAEP is an example for key wrapping when the system requires RSA.

Revision answer: Use hybrid encryption, not direct RSA for entire documents.

3(b)(iii) | Responding to a compromised encryption key

Contain the breach and stop new use of the key. Determine what data and systems were exposed; revoke or disable affected key access, generate a replacement and re-encrypt recoverable stored data under a sound design. Protect new key material, audit activity, restore trustworthy systems and follow applicable incident procedures. Rotation cannot make already copied plaintext or previously decrypted data secret again.

Revision answer: Contain, investigate, replace keys and re-encrypt; prior exposure cannot be undone.

3(b)(iv) | Cloud-backup risks

Risks include misconfigured access, stolen credentials, compromised encryption keys, provider or insider access, deletion/ransomware, outages, loss of recoverability and jurisdictional obligations. Encrypt before upload where appropriate, protect keys separately, restrict permissions, enable versioning/immutability where available and test restores. An encrypted backup is useful only if authorized users can recover its key.

Revision answer: Secure permissions, keys, backup integrity and tested recovery.

3(c)(i) | Why both password hashing and MACs?

Password storage needs a salted, deliberately expensive password-hashing scheme; verification repeats the calculation and compares the result. Transactions need authenticated integrity: a MAC computed with a secret key detects modification and authenticates a party holding that key. A transaction identifier or nonce is also needed to address replay. A plain fast hash does not securely replace a password hasher or a keyed MAC.

Revision answer: Password hashing protects stored verifiers; MACs authenticate transaction integrity.

3(c)(ii) | Unsalted hashes and salting complexity

Without salts, equal passwords yield equal hashes and one precomputed dictionary can be compared with many accounts. Suppose there are U accounts, D guesses and cost C per hash. An attacker can compute D hashes, roughly D*C work, and look up matches across all unsalted accounts. Unique salts prevent reuse across accounts; attacking all accounts with D guesses each requires roughly U*D*C work. Attacking one chosen account still costs roughly D*C. A salt is stored openly and does not increase the password's inherent entropy. Combine unique salts with a costly password-hashing scheme.

Revision answer: Salts defeat cross-account/precomputed reuse; they do not make one weak password unguessable.

4(a) | Number of possible 1-inch QR patterns at 100 PPI

The idealized image contains 100 x 100=10,000 pixels. If every pixel independently has two colors, there are 2^10000 binary patterns. This is not the count of valid QR codes: real QR symbols use structured modules, finder patterns, encoding, version constraints, quiet zones and error correction. PPI alone cannot determine a valid-code count.

Revision answer: Ideal binary patterns: 2^10000. Valid QR-code count is not determined by PPI alone.

4(b) | Primitive root

For a modulus n admitting primitive roots, g is a primitive root if its powers generate every element of the multiplicative group Z*n. Its multiplicative order is phi(n). For example, modulo 7 the powers of 3 yield 3,2,6,4,5,1, covering all nonzero residues. Not every modulus has a primitive root.

Revision answer: A generator of the multiplicative group modulo n.

4(c) | Protocol for S to sign M and V to verify

S computes sigma=Sign(sk_S,M) and sends (M,sigma,issuer-certificate if required). V authenticates S's public key, then checks Verify(pk_S,M,sigma). Accept the claimed signed message only when verification and relevant certificate/status checks succeed. A signature alone does not encrypt M, and freshness may require a nonce or timestamp.

Revision answer: S -> V: (M, signature); V verifies using S's trusted public key.

4(d) | Ransomware

Malware that denies access to data or systems, often by encryption, and demands payment; attackers may also steal data and threaten disclosure. Offline or immutable tested backups, least privilege, patching and incident containment reduce impact.

Revision answer: Malware that extorts payment by denying access or threatening data disclosure.

4(e) | Interpret dr-xr---wx

Split the 10 characters as d | r-x | r-- | -wx. d means directory. Owner can list names and traverse/search, but cannot create/delete entries because write is absent. Group can list names but cannot normally traverse without execute permission. Others can write and traverse but cannot list names. Directory deletion permissions depend mainly on the containing directory and additional controls such as the sticky bit. Numeric permission bits are 543.

Revision answer: Directory; owner r-x, group r--, others -wx (543).

4(f) | Firewall setting to avoid being a Smurf amplifier

Disable forwarding of directed broadcasts at network boundaries and prevent responding to ICMP echo requests addressed to broadcast destinations. Ingress/egress anti-spoofing also limits forged-source traffic. Simply disabling every kind of ICMP can impair legitimate network operation.

Revision answer: Block directed-broadcast amplification and enforce anti-spoofing.

4(g) | Rainbow-table attack

An attacker uses precomputed hash/reduction chains to trade storage and precomputation for faster inversion of unsalted password hashes. Unique per-password salts make a single precomputed table impractical to reuse across accounts. Costly password hashing further increases guessing cost.

Revision answer: Precomputed chains accelerate guesses against unsalted password hashes.

4(h) | Brute force and time-efficiency strategies

Brute force systematically tests candidate keys or passwords until a match is found or the search space is exhausted. Attackers can prioritize likely dictionary/mutation candidates, distribute independent guesses, use suitable hardware, or precompute against unsalted fast hashes. Prioritized guessing is a heuristic shortcut rather than exhaustive enumeration in a fixed order. Rate limiting and costly salted password hashing raise the cost; good randomness raises the search space.

Revision answer: Exhaustive candidate testing; prioritization, parallelism and reusable precomputation can reduce effort.

5(a) | Virtual memory and efficient management

Virtual memory gives each process an address-space abstraction, isolation, protection and the ability to use more address space than physical RAM. The OS maps virtual pages to physical frames using page tables; the MMU translates addresses, and a TLB caches translations. Demand paging loads pages when needed. Good replacement policies, locality and sufficient memory limit expensive page faults. Virtual memory is not inherently faster than direct RAM access; TLBs and locality reduce its overhead.

Revision answer: Page tables map addresses; TLBs accelerate translation; paging must avoid excessive faults.

5(b) | TCP session hijacking

At a conceptual level, an attacker attempts to impersonate a participant in an established TCP connection by obtaining enough session/sequence context to make injected traffic appear valid, or by compromising an endpoint or traffic path. TCP alone does not authenticate application data cryptographically. Authenticated TLS, secure endpoint handling, unpredictable initial sequence values and network anti-spoofing reduce risk; TLS is the core application-data defense.

Revision answer: Hijacking forges participation in an existing connection; authenticated encryption protects its data.

5(c) | Toy Merkle-Damgard-style hash of THIEF

Use the printed recurrence d_i=(26*d_(i-1)+(M_i-'A'+1)) mod 107, with d_0=0 and A=1. T=20 gives d1=20. H=8 gives d2=(20*26+8) mod107=528 mod107=100. I=9 gives d3=2609 mod107=41. E=5 gives d4=1071 mod107=1. F=6 gives d5=32 mod107=32. Although the question mentions 8-bit quantities, its stated modulus is 107; follow that recurrence. The toy construction is not a secure general-purpose cryptographic hash.

Revision answer: Final hash = 32 decimal (0x20).

5(d) | DNS name resolution

The application asks a resolver for a domain's address. A cached answer may be returned immediately. Otherwise a recursive resolver typically queries a root server for the relevant top-level-domain referral, the TLD server for the authoritative server, and the authoritative server for the requested A/AAAA record, following aliases if necessary. It caches results according to TTL and returns them. This is name resolution; HTTPS separately authenticates the server reached.

Revision answer: Resolver -> root -> TLD -> authoritative answer, with caching and possible aliases.

5(e) | Botnets and DDoS

A botnet is a collection of compromised devices remotely coordinated by an operator. A DDoS attack makes many devices generate traffic or resource-consuming requests against a target, exhausting network, compute or application capacity. Multiple sources complicate filtering. Layered protection includes traffic analysis, rate limits, upstream filtering, DDoS mitigation and resilient capacity planning.

Revision answer: Many compromised devices overwhelm one service together.

5(f) | Trojans versus worms

A Trojan disguises malicious functionality as something legitimate and typically relies on a user installing or executing it; self-replication is not its defining trait. A worm self-propagates between systems, often by exploiting vulnerabilities. Malware can combine these behaviors.

Revision answer: Trojan: deceptive delivery. Worm: autonomous propagation.

6(a)(i) | Can ElGamal distribute a key?

Yes: encode a suitable symmetric session key as a message in the supported group and encrypt it to the receiver's authenticated public key. In practice use a vetted hybrid/key-encapsulation construction instead of ad hoc encoding. In this toy example the number M=43 can stand for key material; a modulus of 113 is far too small for real security. Textbook ElGamal is malleable and does not itself authenticate the sender.

Revision answer: ElGamal can carry key material in a hybrid design; authenticate keys and ciphertexts appropriately.

6(a)(ii) | Compute the ElGamal ciphertext

Given p=113, g=34, Bob's private x=97, Alice's fresh k=37 and M=43. Bob publishes y=34^97 mod113=101. Alice computes c1=34^37 mod113=107 and shared factor s=101^37 mod113=45. Then c2=43*45 mod113=1935 mod113=14. One check for c1: 34^2=26, 34^4=111, 34^8=4, 34^16=16, 34^32=30 modulo113; 30*111*34 mod113=107. Ciphertext is the ordered pair (107,14).

Revision answer: Ciphertext (c1,c2) = (107,14).

6(a)(iii) | Decrypt ElGamal and prove correctness

Bob calculates s=c1^x mod p=107^97 mod113=45. The inverse of 45 modulo113 is 108 because 45*108=4860=43*113+1. Therefore M=c2*s^(-1) mod113=14*108 mod113=1512 mod113=43. Generally c1^x=(g^k)^x=g^(kx)=(g^x)^k=y^k. Thus c2/(c1^x)=M*y^k/y^k=M in the multiplicative group.

Revision answer: 14 x 108 mod113 = 43; the shared factors cancel.

6(b)(i) | University portal redirected to a fake site

The scenario is consistent with DNS poisoning or another name-resolution compromise (pharming), so the correct hostname resolves to an attacker-controlled IP. The fake portal then performs phishing to collect credentials and card details. The symptoms alone do not prove the exact compromise: a hosts-file change, malicious resolver or registrar compromise could also explain them. A correctly validated HTTPS connection should reject an attacker lacking a valid certificate for the genuine hostname.

Revision answer: Likely pharming via compromised name resolution, followed by credential phishing.

6(b)(ii) | Defenses against portal redirection

Protect registrar and DNS administration with strong authentication and least privilege; secure and patch resolvers; validate DNSSEC where deployed; use properly validated HTTPS and HSTS; protect endpoints; monitor DNS/certificate changes; and use phishing-resistant authentication where available. Notify affected users and revoke compromised sessions if an incident occurs. DNSSEC authenticates DNS data, while TLS authenticates the web endpoint; they address related but different layers.

Revision answer: Secure DNS administration and resolution, enforce HTTPS validation and strengthen authentication.

6(c)(i) | How a TLS certificate helps against fake websites

During a correctly validated TLS handshake, the browser checks the certificate's hostname, validity and chain to a trusted authority, and the server proves possession of the corresponding private key. An attacker serving a fake site at an unauthorized endpoint cannot normally impersonate the genuine hostname without satisfying these checks. The authenticated handshake establishes protected session traffic. A certificate identifies a domain/key binding; it does not certify that all business content is trustworthy.

Revision answer: Validated TLS authenticates the requested hostname and protects session traffic.

6(c)(ii) | Why customers can still be victims

A phishing site may use a different, lookalike hostname with its own valid HTTPS certificate. Users can be misled by a padlock, bypass warnings, or use compromised devices. For example, a certificate for shop-example-login.com does not authenticate shop-example.com. HTTPS can protect the user's connection to the wrong site.

Revision answer: A valid certificate for a lookalike domain does not make it the real shop.

6(c)(iii) | Certificate and HTTPS best practices

Use a certificate from a trusted authority for the exact hostname, automate renewal, serve the full correct chain, protect private keys and revoke/reissue after compromise. Configure supported secure TLS, redirect HTTP to HTTPS, apply HSTS carefully, avoid mixed content and use secure session-cookie settings. Monitor expiry and certificate issuance. No configuration guarantees every browser will always trust a certificate; trust stores and client clocks also matter.

Revision answer: Maintain valid hostname certificates, safe TLS configuration, key protection and renewal.

Reference reading

William Stallings, Cryptography and Network Security: Principles and Practice.

NIST SP 800-38A: https://csrc.nist.gov/pubs/sp/800/38/a/final

NIST SP 800-63B: https://pages.nist.gov/800-63-4/sp800-63b.html

These are supporting reading references, not claims that this paper or its answer key appears in those books. Course-specific terminology and source ambiguities are noted beside the affected answers.

Shahjalal University of Science and Technology
Department of Computer Science and Engineering
4th Year 1st Semester Final Examination Jan 2024 (Session: 2020-21)
Course Code: CSE 461 Credits: 3 Course Title: Introduction to Computer Security & Forensics
Time: 3 hrs Total Marks: 100

Group A
[Answer all the questions]

1. Answer any FIVE 5x2=10

a) Why is ensuring the CIA triad important in a vulnerable environment?
b) How many different passwords are possible of length 6 with only alphanumeric characters?
c) What dilemma will the attacker face when the ciphertext is less than the unicity distance?
d) Which access control mechanism is the most time-efficient for handling any access-related queries?
e) Mention two tools of integrity.
f) Find Z^*_n and $\phi(n)$ for $n = 14$.
g) Why isn't security by obscurity adopted by the companies?
h) How is the OFB mode capable of encrypting or decrypting all of the blocks parallelly?

2. Answer any FOUR 4x5=20

a) Why do we need asymmetric encryption even after having symmetric encryption?
b) SUST's website uses a privately designed encrypted channel for back-and-forth communication between the server and the clients. SUST invests a significant amount of its budget and takes sophisticated security measures throughout the year to ensure the high security of the whole website. Any user visiting the site can access the results of any student.
Which security principles are violated in the above mentioned scenario? Explain.
c) Consider two passwords:
(i) *Password A:* contains 10 letters chosen from both lowercase and uppercase letters (a-z & A-Z).
(ii) *Password B:* contains 4 letters chosen from lowercase and uppercase letters (a-z & A-Z), 3 numbers (0-9) and 2 special characters (e.g. @, #, $).
Which password is more secure (mathematically and practically) and why?
d) You want to send a 1GB video file securely to your friend. During transmission, some random blocks might be lost. But as it's a video, loss of some random frames shouldn't impact the overall view.
Which AES mode of operation will be more suitable for this operation? Explain.
e) Differentiate between public key cryptography and private key cryptography in terms of their working principles, key usage and security features.
f) Let's assume we represent a hexadecimal character using 4 bits. We consider the following S-box using a bigram table (split 4 bits into 2 bigrams) that is used for encryption and decryption.

	00	01	10	11
00	0011	0100	1111	0001
01	1010	0110	0101	1011
10	1110	1101	0100	0010
11	0111	0000	1001	1100

You're given a ciphertext as: **CB7F1**. Decrypt the text using the given table.

3. Answer any TWO 2x10=20

a) Let SUST has newly introduced the e-certificate using RSA signature. Here, SUST is the issuer, students are the holders, and other authorities verifying the students' documents are the verifiers of the e-certificate. This system needs a rigorous setup and design to work properly.
(i) Create the system design for the e-certificate system with these three entities and with proper setup. Also, verify that your design will work correctly.
(ii) Which attacks should SUST still consider to secure the system?
b) SUST plans to store student data (image, textual information, and large academic documents). IT teams decided to use AES-256 for encryption. Developers used AES in ECB mode for simplicity. For backup, encrypted copies are uploaded to the cloud server.
(i) What problems might arise from using ECB mode?
(ii) Could RSA be a better option for this scenario?
(iii) Some perpetrators have somehow compromised the key. What measures can be taken?
(iv) What risks exist in uploading the backups to the cloud server?

CamScanner

c) A bank is developing a secure banking system. For password storage, they proposed to use a hash function and MACs for the transactions. Developers didn't implement any salting as hash is used and didn't feel salting necessary.
(i) Why are both hashes and MACs necessary for the system? Explain according to the scenario.
(ii) Which risks might still occur for the unsalted hashed passwords? How could salting improve the security? Explain with complexity analysis.

Group B
[Answer all the questions]

4. Answer any FIVE **5x2=10**

a) How many different codes can be generated in a 1 inch x 1 inch QR code with 100 pixels per inch (PPI)?
b) What is a primitive root for any number?
c) Write down the cryptographic protocol for the situation, "S sends a document M to V after signing and V verifies it".
d) What is a ransomware?
e) What is meant by the 10-character access control notation **dr-xr- - - wx** ?
f) What should be your firewall setting if you want to prevent your network from being used for a SMURF DoS attack?
g) Explain rainbow table attack.
h) Define a brute force attack in cryptography. Then, explain the different strategies that can be applied to make a brute force attack more time-efficient.

5. Answer any FOUR **4x5=20**

a) Why do we need virtual memory? How is it managed by the OS to ensure faster execution?
b) Explain how an attacker can impose TCP session hijacking?
c) In Markle-Damgard construction for hashing, let n = m = 8 bits. Assuming and $v = d_0 = 0$ and $C = (M_l , d_{l-1}) = (d_{l-1} * 26 + (M_l - 'A' + 1)) \% 107$. Find the final hash value of the string "**THIEF**".
d) How does DNS name resolution work when you ask for the IP address of any domain name?
e) Explain how botnets can be used to initiate a DDoS attack.
f) Differentiate between trojans and worms.

6. Answer any TWO **2x10=20**

a) Let's assume, Alice wants to send a message **M = 43** to Bob encrypting using Elgamal cryptosystem. You picked a prime number **p = 113** and a primitive root in Z_p is **g = 34**. Next you picked a random number **x = 97** which is your secret key. Alice picked a random number **k = 37**.
(i) Can the Elgamal cryptosystem be used as a mean for key distribution? Explain with an example.
(ii) Find the encrypted pair of the message generated by Alice.
(iii) Write down the equation for the decryption step Bob took and provide its correctness.

b) SUST hosts an online portal for the students for registering courses, checking grades and paying different fees. Recently, the portal has been attacked. Now, if any student tries to visit the portal with proper url, it redirects to the attacker's IP address. The attacker has also implemented a fake but same portal in his IP and hence it can collect credentials and card information also. IT team is getting numerous reports of unauthorized charges and suspicious activities in the students' university accounts.
(i) Explain how this attack is imposed by the attacker?
(ii) Suggest security measures the IT team could have implemented to defend against this attack.

c) An e-commerce website implements HTTPS using a digital certificate to ensure secure online transactions between the server and the customers. The server presents its certificate during TLS handshaking. Still, some customers are falling victim to attacks by some malicious fake websites.
(i) How does a digital certificate protect against an attacker's fake website?
(ii) Why might some users still fall victim? Explain with example.
(iii) Suggest best practices that any e-commerce website should follow to ensure its certificate is always trusted by users' browsers and secure throughout the session?

CamScanner